

STAGE 4

Setting paths:

SRC="/home/user01/ghidra-codeql-analysis/ghidra-10.0.4"

R="/home/user01/ghidra-codeql-analysis/reports"

RULES="\$R/semgrep-rules"

mkdir -p "\$RULES"

Rules:

cat > "\$RULES/ghidra-logging-sinks.yml" <<'EOF'

rules:

- id: ghidra-logging-sink

message: "Ghidra logging sink found."

languages:

- java

severity: INFO

pattern-either:

- pattern: Msg.error(...)

- pattern: Msg.warn(...)

- pattern: Msg.info(...)

- pattern: Msg.debug(...)

- pattern: Msg.trace(...)

- pattern: \$LOGGER.error(...)

- pattern: \$LOGGER.warn(...)

- pattern: \$LOGGER.info(...)

- pattern: \$LOGGER.debug(...)

- pattern: \$LOGGER.trace(...)

EOF

Running semgrep:

```
semgrep scan \  
  --config "$RULES/ghidra-logging-sinks.yml" \  
  "$SRC/Ghidra" \  
  --json-output "$R/semgrep-ghidra-logging-sinks.json" \  
  --sarif-output "$R/semgrep-ghidra-logging-sinks.sarif"  
  
jq '.results | length' "$R/semgrep-ghidra-logging-sinks.json" \  
  | tee "$R/stage4-ghidra-logging-sinks-count.txt"  
  
jq -r '  
  .results[]?  
  | [  
    .check_id,  
    .path,  
    .start.line,  
    .end.line,  
    .extra.message  
  ]  
  | @tsv  
' "$R/semgrep-ghidra-logging-sinks.json" \  
  | tee "$R/stage4-ghidra-logging-sinks-summary.tsv"  
  
jq -r '
```

```
.results[]?  
| "\n==== " + .path + ":" + (.start.line|toString) + " ====\n" + (.extra.lines // "")  
' "$R/semgrep-ghidra-logging-sinks.json" \  
| tee "$R/stage4-ghidra-logging-sinks-snippets.txt"
```